INFORME EJECUTIVO Y TÉCNICO DE PENTESTING



Evaluación de Seguridad Ofensiva, Hackeo Ético
y Verificación OWASP ASVS v4.0.3

Índice / Tabla de Contenidos

1. Resumen Ejecutivo y Ficha Técnica Pág. 3

2. Metodología de Evaluación y Estándares Aplicados Pág. 4

2.1 Marcos Normativos Utilizados Pág. 4

2.2 Escala de Severidad y Prioridad Pág. 4

3. Métricas y Distribución Estadísticas de Hallazgos Pág. 5

Gráficos de Distribución (Barras — Estado del Ticket) Pág. 6

Gráficos de Distribución (Torta — Severidad) Pág. 7

4. Alcance Técnico y Componentes Evaluados Pág. 8

5. Detalle de Vulnerabilidades e Incidencias Registradas Pág. 9

Prueba de Concepto (PoC) paso a paso Pág. 10

Evidencias Fotográficas (Capturas de Pantalla) Pág. 11

6. Conclusiones y Plan de Remediación Recomendado Pág. 12

1. Resumen Ejecutivo y Ficha Técnica

Durante la revisión del laboratorio «Turnero» (Módulo I, Objetivo 2), aplicando lo visto en la Clase 5 sobre Security Misconfiguration, detecté que la cookie de sesión «session» se transmite sin el flag Secure y que el servidor no envía la cabecera HSTS (Strict-Transport-Security).
En conjunto, si el navegador llega a conectarse por HTTP la cookie de sesión viaja en texto plano y cualquier atacante posicionado en la misma red podría capturarla y secuestrar la sesión de otro usuario, sin robar ni adivinar ninguna contraseña. Severidad: ALTA (CVSS 7.4). Se recomienda agregar los flags Secure y SameSite e implementar HSTS antes del pase a producción.

Parámetro / Campo	Detalle de la Evaluación
Tipo de Evaluación	Penetration Testing (Caja Gris) — Security Misconfiguration
Estándar Principal	OWASP ASVS 4.0.3 (Level 2/3) & OWASP Top 10
Período de Pruebas	Octubre 2026 — Laboratorio de práctica (Módulo II · Objetivo 1)
Entorno de Evaluación	Ambiente de Laboratorio — Aplicación «Turnero»
Clasificación del Documento	**ESTRICTAMENTE CONFIDENCIAL**

2. Metodología de Evaluación y Estándares Aplicados

Las pruebas se ejecutaron combinando análisis estático (SAST), análisis dinámico (DAST) y pruebas de penetración manuales profundas, para reducir falsos positivos y garantizar la exhaustividad del análisis.

2.1 Marcos Normativos Utilizados

OWASP ASVS v4.0.3

Verificación estructurada de controles de seguridad en arquitectura, autenticación, control de acceso y criptografía.

OWASP Top 10

Clasificación de las vulnerabilidades web más críticas: inyecciones, fallos de control de acceso, criptografía deficiente, entre otras.

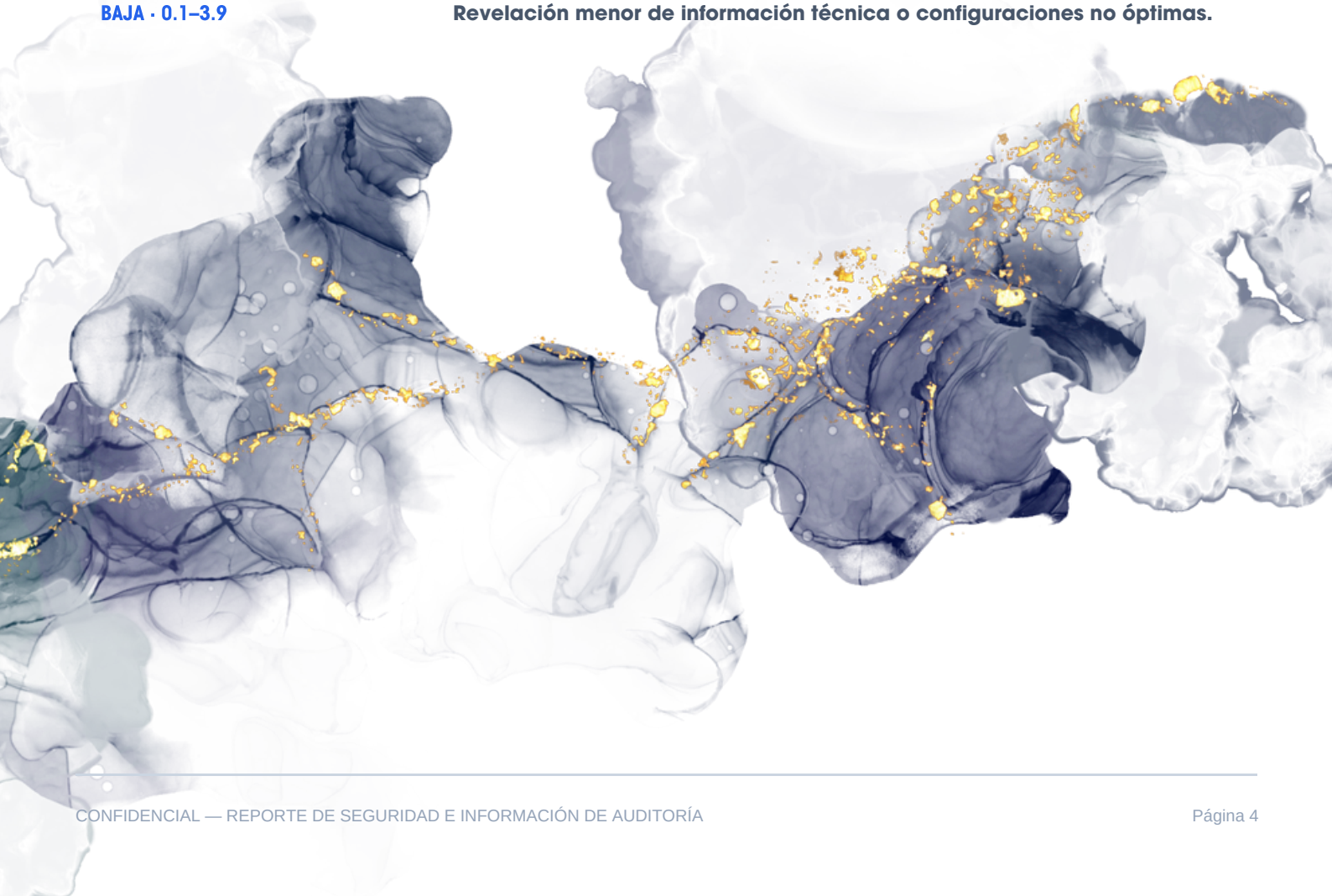
PTES — Penetration Testing Execution Standard

Guía de fases del pentest: reconocimiento, descubrimiento, explotación y post-explotación.

2.2 Escala de Severidad y Prioridad (CVSS v3.1)

Los hallazgos se evalúan bajo la matriz CVSS v3.1, clasificándose en cuatro niveles:

CRÍTICA · 9.0–10.0	**Ejecución remota de código o acceso total al sistema sin autenticación.**
ALTA · 7.0–8.9	**Compromiso grave de confidencialidad o integridad con impacto sustancial.**
MEDIA · 4.0–6.9	**Fallos de lógica o bypass de controles que requieren condiciones previas.**
BAJA · 0.1–3.9	**Revelación menor de información técnica o configuraciones no óptimas.**



3. Métricas y Distribución Estadística de Hallazgos

A continuación se consolidan las métricas del hallazgo registrado durante esta auditoría puntual (laboratorio Turnero — Security Misconfiguration / cookie sin flag Secure + HSTS).

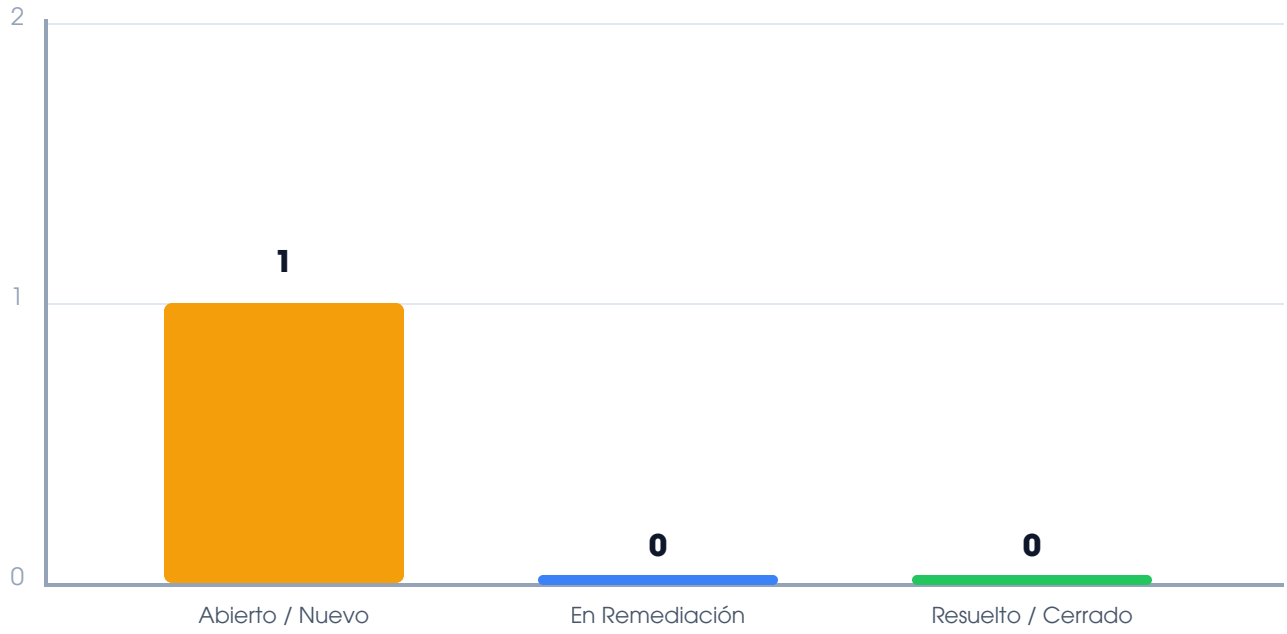
1	1	0	0
Hallazgos totales	Severidad Alta	Severidad Media	Severidad Baja

Distribución por estado del ticket

Estado del hallazgo	Cantidad	Porcentaje
Abierto / Nuevo	1	100%
En Remediación	0	0%
Resuelto / Cerrado	0	0%
Total	**1**	**100%**

Distribución por Estado del Ticket

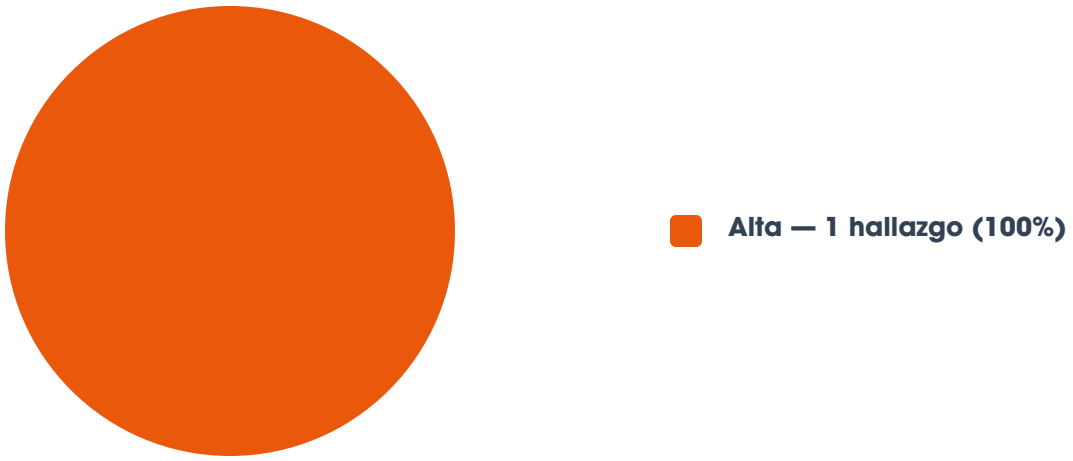
El gráfico de barras muestra cómo se reparten los hallazgos según su estado de gestión al cierre de la auditoría.



Cada barra representa la cantidad de hallazgos en ese estado. El único hallazgo de esta auditoría se encuentra actualmente Abierto, pendiente de remediación.

Distribución por Severidad

La torta muestra la proporción de hallazgos según su nivel de severidad CVSS.



El único hallazgo de esta auditoría es de severidad Alta (CVSS 7.4) y concentra el 100% del riesgo identificado.

4. Alcance Técnico y Componentes Evaluados

Esta auditoría se centró en la configuración de seguridad (Security Misconfiguration), revisada de forma pasiva con DevTools. A continuación, qué se evaluó y qué quedó fuera de alcance:

Autenticación y Gestión de Sesiones — Evaluado

Atributos de la cookie de sesión «session»: HttpOnly presente (correcto), pero sin el flag Secure y con SameSite sin definir — origen del hallazgo VULN-001.

Control de Acceso e Impersonación — Fuera de alcance

No se evaluó en esta auditoría puntual; el foco fue la configuración de seguridad, no la lógica de autorización.

Validación de Entradas y Sanitización — Fuera de alcance

No se probaron inyecciones (SQLi, XSS, Command Injection, SSRF) en esta auditoría puntual.

Seguridad en Comunicaciones y Criptografía — Evaluado

Ausencia del flag Secure y de la cabecera HSTS (posible transmisión en claro por HTTP), además de las 6 cabeceras de hardening HTTP ausentes (CSP, X-Frame-Options, etc.).

Manejo de Errores y Registro de Eventos — Evaluado (sin hallazgo)

Se forzó un error navegando a una ruta inexistente: el servidor respondió 404 genérico, sin stack trace ni datos internos expuestos.

5. Detalle de Vulnerabilidades e Incidencias Registradas

Se detalla el hallazgo principal identificado, con su descripción técnica, clasificación normativa y desglose de severidad CVSS.

VULN-001 · Cookie de sesión sin flag Secure + ausencia de HSTS **ALTA · CVSS 7.4**

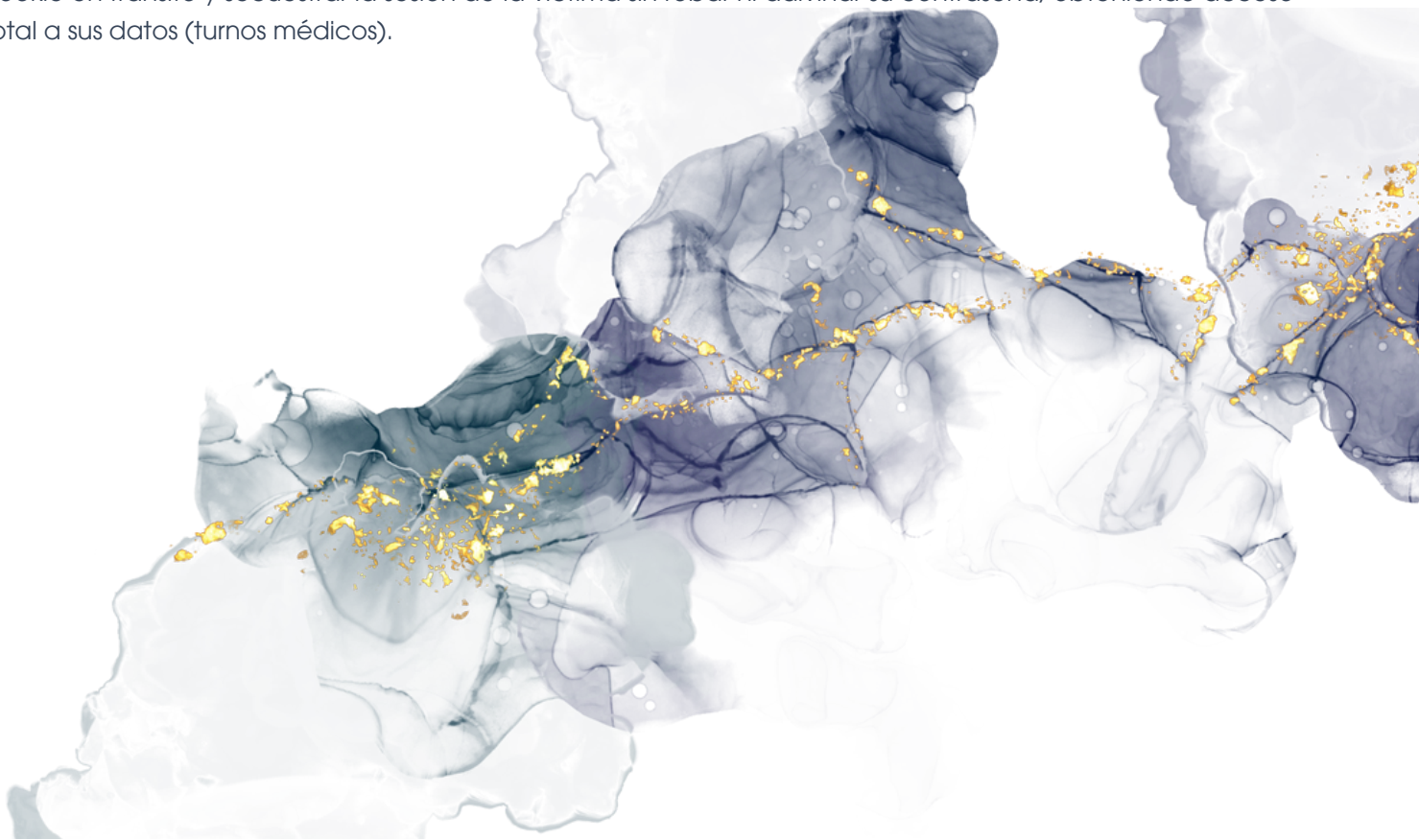
CWE	CWE-614 — Sensitive Cookie Without 'Secure' Attribute (agravado por CWE-319)
OWASP Top 10	A05:2021 — Security Misconfiguration
Vector CVSS 3.1	**AV:N / AC:H / PR:N / UI:N / S:U / C:H / I:H / A:N**
Estado	**Abierto**

Descripción técnica

La cookie de sesión «session», que identifica la sesión autenticada, se emite con HttpOnly pero sin el flag Secure, y el servidor no envía la cabecera HSTS (Strict-Transport-Security). Como nada le indica al navegador que rechace una conexión HTTP, si en algún momento llega a conectarse por HTTP la cookie viaja en texto plano y puede ser interceptada.

Impacto

Un atacante posicionado en la misma red (Wi-Fi compartida, router comprometido, MITM) puede capturar la cookie en tránsito y secuestrar la sesión de la víctima sin robar ni adivinar su contraseña, obteniendo acceso total a sus datos (turnos médicos).



Prueba de Concepto (PoC) — Paso a Paso

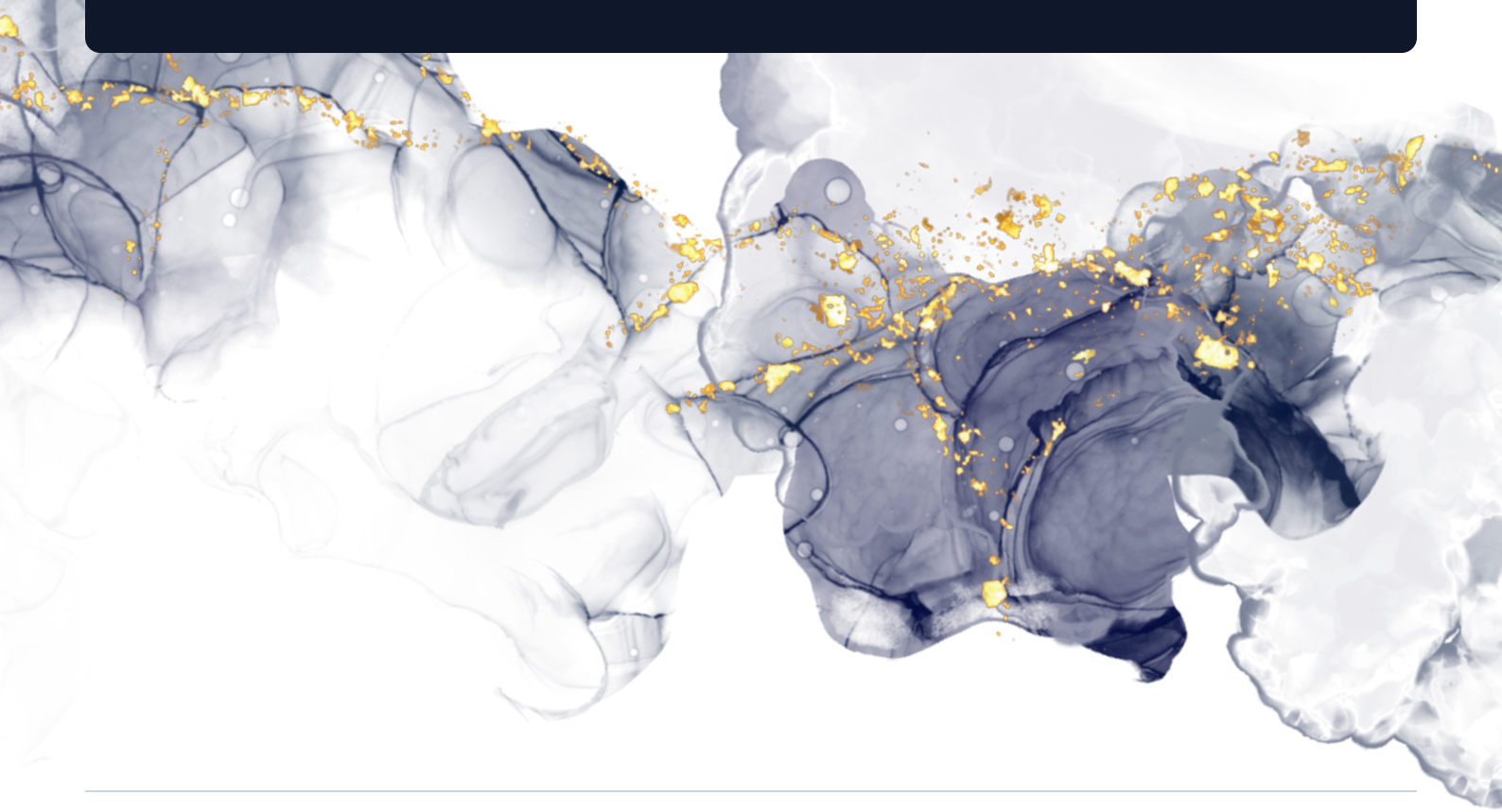
Reproducción completa del hallazgo en el laboratorio Turnero, de forma íntegramente pasiva (solo inspección con DevTools). Cada paso es reproducible y verificable.

1. Iniciar sesión como usuario común («luis») en el laboratorio Turnero y abrir las DevTools del navegador.
2. En la Consola, ejecutar document.cookie: solo aparecen las cookies de analítica, no la cookie «session» — confirma que HttpOnly está activo (correcto).
3. En Aplicación → Almacenamiento → Cookies, revisar los flags de «session»: HttpOnly presente, pero Secure en false y SameSite sin definir.
4. En la pestaña Red, inspeccionar GET /api/1/appointments/ y confirmar que la cookie «session» se adjunta en cada request autenticado.
5. En las Cabeceras de la respuesta, verificar que faltan las 6 cabeceras de seguridad (CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy).
6. **Forzar un error en una ruta inexistente → 404 genérico sin stack trace. Todo verificado de forma pasiva, sin modificar ni reenviar ninguna petición.**

```
// Aplicación → Cookies → session
HttpOnly: true (OK)   Secure: false (FALLA)   SameSite: sin definir

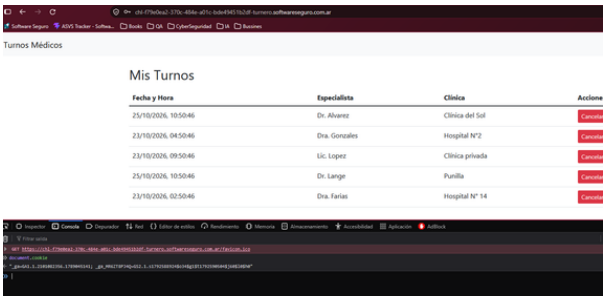
// GET /api/1/appointments/ – Cabeceras de respuesta
access-control-allow-origin: *
(sin HSTS, CSP, X-Frame-Options, X-Content-Type-Options...)

> document.cookie   // en la Consola
"_ga=...; _ga_MR6ZT8PJ4Q=..."  // «session» no aparece -> HttpOnly OK
```

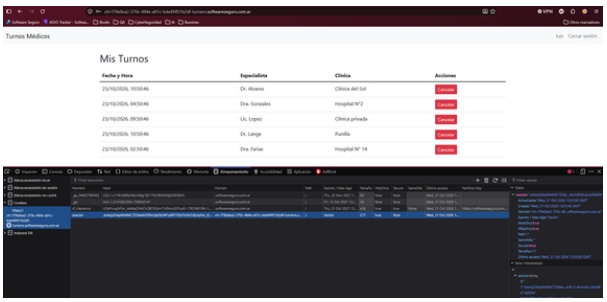


Evidencias

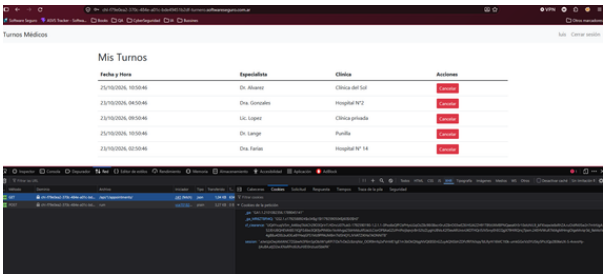
Capturas obtenidas durante la auditoría pasiva con DevTools. Cada imagen documenta uno de los pasos del PoC. Arrastrá cada captura sobre su recuadro.



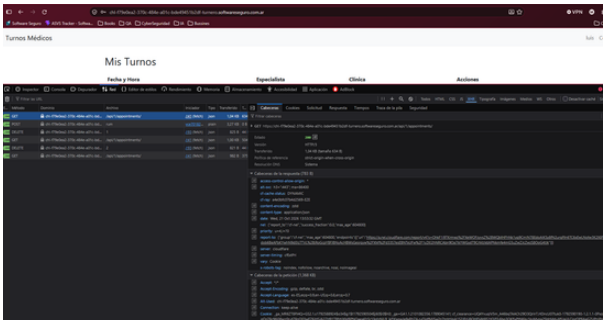
1 · Consola — document.cookie solo devuelve las cookies de analítica; «session» no aparece (HttpOnly activo).



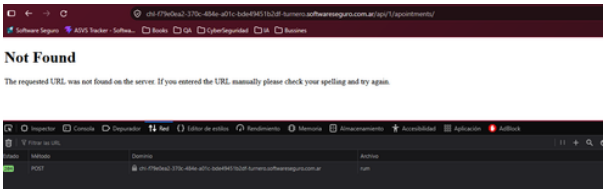
2 · Aplicación → Cookies — la cookie «session» tiene HttpOnly en true, pero Secure en false y SameSite sin definir.



3 · Red — la cookie «session» se adjunta en la petición GET /api/1/appointments/.



4 · Cabeceras de respuesta — faltan CSP, HSTS, X-Frame-Options y las demás cabeceras de seguridad; CORS con Access-Control-Allow-Origin: *.



5 · Manejo de errores — una ruta inexistente devuelve 404 genérico, sin stack trace.

6. Conclusiones y Plan de Remediación Recomendado

Se recomienda priorizar la corrección del hallazgo Alto antes del pase a producción. A continuación, la corrección técnica y el plan de verificación.

Corrección recomendada — Asegurar la cookie de sesión e implementar HSTS

```
// Configuración segura de la cookie de sesión
res.cookie("session", token, {
  httpOnly: true,    // ya presente
  secure: true,      // <- FALTABA: solo viaja por HTTPS
  sameSite: "lax"    // <- mitigación CSRF
});

// Forzar HTTPS en toda la app (cabecera HSTS)
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

Plan de acción y timeline

INMEDIATO (0–24 h)	Agregar el flag Secure a la cookie «session» y activar HSTS para forzar HTTPS.
CORTO PLAZO (1–3 d)	Definir SameSite=Lax y sumar el resto de cabeceras de hardening (CSP, X-Frame-Options, etc.).
VERIFICACIÓN (3–5 d)	Ejecutar el re-test de las cabeceras y la cookie, y cerrar formalmente el ticket.

Criterios de verificación (re-test)

- La cookie «session» se emite con Secure y SameSite; el navegador solo la envía por HTTPS.
- El servidor responde con la cabecera HSTS (Strict-Transport-Security).
- Las 6 cabeceras de seguridad están presentes y CORS ya no usa wildcard (*).

Elaborado por
María de los Ángeles Acuña
QA Tester

Revisado y aprobado por
Lead Security Auditor / CISO
Firma: _____



